

Security Advisory: Phishing Campaign Analysis & Prevention

Prepared By: M Pasumponrajan
Security Analyst Intern

Date: 30/05/2026

Audience: All staff & Employees

Risk Classification:  DEFINITIVE
PHISHING

1. Incident Summary

Recently, our security operations team intercepted a phishing campaign targeting employee inboxes. The objective of this attack is to harvest employee login credentials by creating a false sense of urgency regarding an "Account Lockout."

This document outlines the anatomy of this specific attack, provides the technical evidence confirming it is malicious, and lists actionable guidelines to help employees protect themselves and the company.

2. Anatomy of the Attack (Visual Breakdown)

Below is the exact text of the intercepted phishing email. Our security team has highlighted the specific "Red Flags" that prove this is a malicious attempt.

Sample Email Text:

Subject: ⚠ Urgent: Your Account Will Be Locked

Dear User,

We noticed suspicious activity on your account. To avoid account suspension, please verify your details immediately.

👉 Verify Now: <http://secure-account-verify.com>

Failure to verify within 24 hours will result in permanent account lock.

Regards, Security Team

Identified Phishing Indicators (Red Flags):

1. Psychological Urgency & Fear: The attacker uses phrases like "Account Will Be Locked" and "Failure to verify within 24 hours." This is designed to force the employee to panic and click the link without thinking critically.
2. Generic Greetings: The email begins with "Dear User." Legitimate corporate communications from IT, HR, or banking institutions will address you by your actual name.
3. Vague Sign-off: The email is signed broadly as the "Security Team" without providing an actual name, department location, or verified contact number.
4. Suspicious Destination Link: While the email claims to be an internal security alert, the destination URL (secure-account-verify.com) is a third-party, look-alike domain not owned by our company. Note: The presence of HTTPS (a padlock icon) does not guarantee a site is safe; it only means the connection is encrypted.

3. Technical Evidence (IT Reference)

Header analysis of the inbound email confirms that the message was spoofed. Technical investigation yielded the following results:

- SPF (Sender Policy Framework): FAIL - The sending IP address is not authorized to send emails on behalf of the claimed domain.
- DKIM (DomainKeys Identified Mail): FAIL - The cryptographic signature is invalid, indicating the email source is fraudulent or was tampered with in transit.

Due to the combination of social engineering tactics and technical authentication failures, this email has been classified as a definitive phishing threat.

4. Employee Prevention Guidelines (Do's and Don'ts)

Human awareness is our strongest defense against phishing attacks. Please adhere to the following guidelines:



DO:

- Hover before you click. Always hover your mouse pointer over a link to inspect the true destination URL before clicking it.
- Verify out of band. If an email claims to be from a coworker or department urgently requesting information, call or message them directly via Slack/Teams to verify.
- Report it. If you see something suspicious, use the "Report Phishing" button in your email client or forward it to the IT Helpdesk immediately.

DON'T:

- Don't let urgency force a mistake. Attackers rely on panic. Take a deep breath and review the email logically.
- Don't open unexpected attachments. Unless you were specifically expecting a file from a known sender, do not open PDF, ZIP, or Microsoft Office attachments.
- Don't submit passwords to external forms. IT will never ask you to verify your password via an external web form.